

Kifisias Avenue 1-3, 11523 Athens
Tel: 210 6475 600 • E: contact@dpa.gr • www.dpa.gr

Athens, 05-12-2023

Ref. No.: 3108

DECISION 35/2023

(Section)

The Hellenic Data Protection Authority convened, following an invitation from its President, in a regular session in the composition of a Section at its headquarters on 08/11/2023, in order to examine the case referred to in the background of this document. Participating in the session via videoconference was Georgios Batzalexis, Deputy President, in the absence of the President of the Authority, Konstantinos Menoudakos, and the alternate member Nikolaos Libos, as rapporteur, along with the alternate members Dimosthenis Bougioukas and Maria Psalla, replacing the regular members Konstantinos Lamprinouidakis and Grigorios Tsolias who were unable to attend despite being duly summoned in writing. Also present at the session, by order of the President without voting rights, were Charis Symeonidou, special scientist – auditor as assistant rapporteur, and Irini Papageorgopoulou, staff member of the administrative affairs department of the Authority, as secretary.

The Authority took into account the following:

With the complaint numbered G/EIS/10503/28-09-2022, A (hereinafter the complainant) is directed against Alpha Bank (hereinafter the complained party), of which he is a customer and holder of a credit card, for the illegal and unnotified provision of his personal data to his wife. Specifically, according to the complaint, on ... of ..., the complained Bank provided the complainant's wife, upon her request, with information regarding the fact that the complainant holds a credit card in his name, as well as printed receipts of all transactions that the complainant had made with the said credit card in the previous 3-4 months, i.e., information that falls under banking secrecy. As the complainant argues, the fact that the printing was done at an Alpha Bank branch was confirmed by an employee of the Alpha Bank branch in F to whom the complainant showed the relevant photographs, while the complaint indicates that there was no prior notification to the complainant as the data subject before the transmission. Additionally, the complainant states that he has already referred the alleged facts to the Consumer Ombudsman, while he regularly received SMS from the complained Bank with the message that efforts are being made to find the best solution for his case. The complainant also mentions that the reason he had issued the said credit card is that Finally, from the complaint, it appears that as a result of the unlawful leak of information regarding the existence and transactions of the complainant's credit card, the family peace and his relationship with his wife were significantly disrupted (...).

In the context of investigating the complaint, the Authority, with document G/EXE/3243/13-12-2022, invited the complained party to express its views on the allegations, clarifying in particular, a) whether the complained party provided information regarding the transactions that had been made through the complainant's personal credit card to his wife, on what legal basis and procedure, and why the complainant as the data subject was not informed about this, b) when the complained party became aware of the alleged incident from the complainant and what actions it subsequently took. In its response, the Bank was requested to submit its relevant Policies and clarify whether the provisions therein were adhered to in this case, specifically determining whether it treated the allegations as a personal data breach incident in accordance with Articles 33-34 of the GDPR and justifying its response.

In its response numbered G/EIS/125/09-01-2023, the complained Bank stated the following:

3

- That the complainant is a client of Alpha Bank, as is his wife, and on ... he submitted a complaint regarding the leakage of his personal data, specifically transactions of his credit card ..., which had been issued in his name without any additional cardholder. According to the Bank, the competent Service received the request, but the information provided by the complainant was insufficient to initiate a related investigation, as it was necessary to identify the method and source of the leakage, given that it could potentially be any Branch of the Bank, while the time frame for the investigation

could not be determined, as only the end of the relevant period was known (on ...) and not its beginning. The respondent, however, states that the client – complainant suspected that the source of the leakage was Branch X and that he was informed regarding the receipt of the request and the initiation of its processing through three (3) SMS messages (on ... and ...).

- That on ... the complainant followed up with a newer message via e-mail, attaching a black-and-white photograph of a copy of the transactions of his card account, which he claimed had been transmitted/delivered to his wife by an unknown Bank employee “at Y or Z.” Following this, the Bank's Service forwarded, according to the response of the respondent, on ... the complainant's request to the competent Internal Audit Department in order to initiate a related investigation, but due to an oversight, as it states, it did not forward the additional information received on ..., resulting in the Internal Audit requesting clarifications and further information from the Bank's Service managing the case on ... due to the lack of information that would limit the scope of the investigation. It also claims that for this difficulty in the Bank's immediate response, the complainant was informed with four (4) SMS messages to his mobile phone dated (... and ...).

- That subsequently, on ... the respondent received through the Consumer Advocate a request/report from the complainant regarding the same issue, in which it was stated that his wife on ... showed him as “evidence” copies of the transactions of his card account, claiming that these documents had originated from her access to web banking by intercepting his credentials. This request included the black-and-white photograph of the aforementioned account copy as well as newer information regarding the case, and thus, according to the said response, the Bank's Service on ... contacted the Internal Audit again providing all the information it now had at its disposal, so that the relevant investigation could be initiated, while on ... an employee of the competent Service called the complainant for the provision of clarifications and the confirmation of the information that had been brought to its attention.

- That on ... the relevant report of the Internal Audit was issued, confirming the leakage of the complainant's personal data, for which responsibility is attributed to an employee of Branch Ω X (with code ...). Nevertheless, according to the report, no malice was diagnosed on the part of the employee since, as the Bank states: a) the complainant's personal data were disclosed following a request from a direct relative (spouse), b) the complainant's wife, who was mistakenly the recipient of his data, is a co-holder of other products of the Bank as well as the holder of an additional credit card with the complainant as the main cardholder, c) the leakage occurred in the context of servicing/informing the complainant's wife about a series of products, in which she is a holder or co-holder, the last of which concerns the disputed credit card of her complainant husband, and d) the complainant's wife misled the Branch employee by claiming that she allegedly had the relevant authorization from the cardholder and her husband for the receipt of a copy of the transactions of his credit card. Furthermore, regarding the management of the incident as a violation of personal data, in the same response, the respondent Bank stated the following:

- That with the confirmation of the Breach of Data Confidentiality, the bank, through its competent Services, undertook a series of actions: • On ... the Operational Risk Event Management Council convened and, among other things, decided to refer the employee for whom responsibilities arose to the Disciplinary Council for non-compliance with the Bank's Policies.

5

- On ..., the Data Breach Incident Assessment Committee convened in accordance with the relevant Policy of the Bank, which assessed that, based on the circumstances of the incident and particularly that the unauthorized recipients of the data are limited to one individual related to the complainant (spouse), "there does not appear to be a risk to his freedoms and rights as a data subject."
- The incident was recorded in the Data Breach Incident Register (attached as Annex 1) and the Data Breach Risk Analysis Form was completed (attached as Annex 2). According to this Risk Analysis Form, the risk to the data subject is assessed as "negligible."
- On ..., the complainant was informed via email about the incident and the outcome of the relevant investigation, and

- On ..., the Disciplinary Council of the Bank convened and a relevant decision is pending.

Based on the above, the Bank asserts that it examined the complainant's request with due diligence, that it "proceeded with the necessary investigation when it had the necessary information to conduct the relevant check, as the temporary lack of such information made it impossible to conduct it or would lead to the employment of disproportionately increased resources and would significantly prolong its conduct." Finally, the Bank, in the same document, submitted to the Authority the Personal Data Protection Policy (Annex 4), the Group Cybersecurity and Information Security Framework (Annex 5), and the Personal Data Breach Notification Procedure (Data Breach Management) (Annex 6) and emphasized that it undertakes initiatives for the continuous training of its staff on data protection issues. In this document, among other things, the following is provided:

"2.1 REPORTING OF SUSPECTED INCIDENT

All potential security incidents, including those that may constitute breaches or confirmed incidents of personal data breaches, are reported immediately:

- via email:

To: privacy@alpha.gr

Cc: Market and Operational Risk Management

or

- by phone, tel. 210 326 6965, to the Support Operations Department, which immediately informs the following:

- o the Group Data Protection Officer (hereinafter "GDPO") and

- o the Cybersecurity and Information Security Department (hereinafter "CISD")

Potential security incidents may be reported to the Bank, in its capacity as data controller, by the following:

1. Units of the Bank: They report incidents that come to their attention, which may relate to a security incident, specifically a personal data breach. These Units promptly complete the "Operational Risk Event Notification" form (Form Code 15031), as provided in the Operational Risk Management Policy, and send it via email based on the above." [...]

"2.4 ASSESSMENT OF PERSONAL DATA BREACH INCIDENT

It is very important, as soon as it is confirmed that the incident involves a personal data breach, not only to carry out the initial actions to address it but also to assess the risk of the breach incident, based on the potential impacts it may have on the rights and freedoms of the data subjects."

Following the above, the Authority, with calls G/EXE/730/22-03-2023 and G/EXE/731/22-03-2023 respectively, summoned the complainant and the accused to a hearing via videoconference before the Department of the Authority on ..., in order to present their views on the case. During the meeting

7

of ..., the case was postponed at the request of the respondent, for the session of ..., at which it was postponed again, at the request of the complainant, for the session of

At the session of ..., the complainant and, on behalf of the respondent Bank, the lawyers Ioannis Mourgelas (AM DSA ...) and Angeliki Sakopoulou (AM DSA ...) attended via videoconference, while B, the Data Protection Officer of the Bank, was also present. During the hearing, the parties presented their views and were given a deadline for the submission of a memorandum. Subsequently, the respondent submitted in due time the memorandum dated ... with reference number G/EIS/4899/03-07-2023, while the complainant did not submit a memorandum.

During the hearing, the complainant reiterated the points made in his complaint, emphasizing the fact that the credit card was solely in his name, that both he and his wife are "Gold Members" of the respondent Bank, and that his wife is a regular customer at branch X. He stated that in the context of the adjudication of his lawsuit against the respondent Bank, an employee of the latter falsely testified that his wife had his authorization to obtain information regarding his credit card and that the Bank, after sending him messages (sms) apologizing for the delay for 3-4 months, ultimately informed him via email that it was correct to provide the information to his wife because she had his authorization, which, as the complainant argues, was not the case. Furthermore, as the complainant clarified, his

wife did not know his card number.

The respondent, both during the hearing and in its memorandum dated ..., argued that in the initial complaint dated ..., the complainant did not specify the branch from which the leak occurred "not even by area," resulting in it being objectively impossible for the investigation to lead to a specific conclusion. However, the respondent presents the said request (as attachment 1), from which it appears that the complainant explicitly states that he "suspects branch X," while in its document G/EIS/125/9-1-2023, the respondent mentions that the complainant in his initial request "speculated that the source of the leak was branch X." Furthermore, the respondent argued during the hearing and in its memorandum that, although in his second request dated ... the complainant submitted a photo printout (on ...) of the account activity of his card which had been given to his wife and although he specified that the leak occurred between Y and X, the Bank was still unable to identify the source of the leak, given that the exact time of the leak was not specified. Specifically, the Bank states that along the coastal front between Y and X, there are ... of its branches, where ... employees serve, and in each of these, an average of 100-120 transactions are conducted daily; therefore, its investigation, even for a period of 35 working days (from ... to ...), would have to cover many thousands of transactions. Consequently, according to the respondent Bank, "the very great difficulty in completing such a task to determine whether there was indeed a leak, from which branch, and which specific data were involved is evident." Additionally, the respondent reiterated the claim that when the request from the complainant dated ... was forwarded to ... to the Bank's Internal Audit Department to initiate an investigation, the additional information, namely the submitted photo of the account activity printout of the complainant's card, was inadvertently not forwarded, adding that this oversight was due to the fact that it was "not a complete photo of a monthly statement of a card." Furthermore, according to the respondent, this photo does not mention any branch but only the date of issuance of the account activity statement (...), the name of the holder, the card number, the credit limit, and the new (debit) balance, as well as the details of the transactions that took place during the period covered by the statement. According to the Bank, the leak of the transaction data depicted in this "does not seem to pose even the slightest risk to the freedoms and rights of the cardholder," because "these are limited to the dates on which the transactions were made, to the businesses where these were conducted, such as ..., as well as to the amount of each transaction, without any reference whatsoever to the specific goods or services purchased, making it objectively impossible to correlate these transactions with any person for whom they were made," and because they were of low amounts,

9

as "daily micro-transactions." Furthermore, the Bank claims that the complainant did not provide it with all the information available to him for the purpose of investigating the incident, as the claim by his wife that she had used his web banking credentials became known to the bank for the first time on ..., when the pending report before the Consumer Ombudsman was communicated to it. Moreover, as the complainant stated in his message dated ... and during the hearing, although he was aware of the branch and the employee responsible, he did not want to mention them to the Bank. For this reason, the accused Bank argues that the complainant bears significant responsibility for the delay in investigating the incident. Additionally, the Bank states that the responsible employee wrongly accepted the oral authorization of the husband as sufficient, despite the internal procedures and instructions of the Bank; however, she acted in good faith due to her being misled, with the aim of serving the customer, based on the long-standing relationship of the couple with the Bank, the number of their joint products, and the fact that the wife was aware of the existence and the number of the complainant's credit card. Subsequently, the Bank asserts that the incident was treated as a violation of personal data, all relevant recording and handling procedures were followed, the responsible employee was referred to the Disciplinary Council and was strictly punished with a disciplinary penalty of suspension for one (1) month, while there was no notification to the data subject under Article 34 of the GDPR since the subject had informed the Bank about the incident, nor to the Authority under Article 33 of the GDPR, because "it concerned only one subject and there was no case that it would affect the rights and freedoms of the subject himself or other natural persons." In its memorandum, the Bank submits the initial complaint from ... of the complainant, the informative SMS messages sent to

him by the Bank, the black-and-white photo of the printout, the complaint to the Consumer Ombudsman, the request from ... of the complainant, a sworn statement from the manager (at the time of the incident) of the Branch Ω X, as well as again the Bank's Data Protection Policy, which had also been submitted as reference 4 of its response document with protocol number G/EIS/125/09-01-2023.

10

The Authority, after examining the file's elements and having heard the rapporteur and the clarifications from the assistant rapporteur, who attended without voting rights, following thorough discussion,

CONSIDERED IN ACCORDANCE WITH THE LAW

1. From the provisions of Articles 51 and 55 of the General Data Protection Regulation (Regulation (EU) 2016/679 – hereinafter, GDPR) and Article 9 of Law 4624/2019 (Government Gazette A' 137), it follows that the Authority has the competence to supervise the application of the provisions of the GDPR, this law, and other regulations concerning the protection of individuals from the processing of personal data. Specifically, from the provisions of Articles 57 paragraph 1 point (f) of the GDPR and 13 paragraph 1 point (z) of Law 4624/2019, it follows that the Authority has the competence to address the complaint of A against Alpha Bank and to exercise, correspondingly, the powers granted to it by the provisions of Articles 58 of the GDPR and 15 of Law 4624/2019.

2. With Article 5 paragraph 1 of the General Regulation (EU) 2016/679 for the protection of individuals against the processing of personal data (hereinafter GDPR), the principles that must govern a processing are established. According to Article 5 paragraph 1 (a) and (f) of the GDPR, "1. Personal data shall be: a) processed lawfully and fairly in a transparent manner in relation to the data subject ('lawfulness, fairness, and transparency'), [...] f) processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures ('integrity and confidentiality')," while as noted in the Preamble of the Regulation, "Personal data should be processed in a manner that ensures appropriate protection and confidentiality of personal data, including to prevent any unauthorized access.

11

"to this personal data and the equipment used for their processing or the use of this personal data and the said equipment" (Recital 39 in fine). Furthermore, according to the principle of accountability explicitly defined in the second paragraph of the same article and which constitutes a cornerstone of the GDPR, the data controller "bears the responsibility and is able to demonstrate compliance with paragraph 1 ('accountability')." This principle entails the obligation of the data controller to be able to demonstrate compliance with the principles of Article 5 paragraph 1.

3. According to the provision of Article 24 paragraph 1 GDPR: "1. Taking into account the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller implements appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is performed in accordance with this Regulation. These measures are reviewed and updated as necessary," while according to the provisions of paragraphs 1 and 2 of Article 32 GDPR regarding the security of processing, "1. Taking into account the latest developments, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller and the processor implement appropriate technical and organizational measures to ensure an appropriate level of security against the risks, [...] 2. In assessing the appropriate level of security, particular consideration is given to the risks arising from the processing, in particular from accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or access to personal data that have been transmitted, stored, or otherwise processed."

4. According to Article 4 paragraph 12 GDPR, a personal data breach is defined as "a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or

access to personal data that have been transmitted, stored, or otherwise processed." According to the Guidelines 18/2018 of the Article 29 Working Party of Directive 95/46/EC (now European Data Protection Board) on Personal Data Breach Notification ("Guidelines on Personal data breach notification under Regulation 2016/679" WP 250 rev. 1), one type of personal data breach is categorized based on the security principle of "confidentiality," when unauthorized access to personal data is detected ("confidentiality breach"). A breach may potentially have various significant adverse consequences for individuals, which can lead to physical, material, or moral harm. The GDPR explains that this harm may include loss of control over their personal data, restriction of their rights, discrimination, identity theft or misuse, financial loss, unlawful reversal of pseudonymization, damage to reputation, and loss of confidentiality of personal data protected by professional secrecy, etc. (see also recitals 85 and 75).

5. Data breach incidents must be reported to the Authority within 72 hours from the moment the data controller becomes aware of them, according to Article 33 paragraph 1 GDPR: "1. In the case of a personal data breach, the data controller shall notify without undue delay and, where feasible, within 72 hours of becoming aware of the breach, the supervisory authority competent pursuant to Article 55, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. When the notification to the supervisory authority is not made within 72 hours, it shall be accompanied by reasons for the delay." Furthermore, according to recital 85, as soon as the data controller becomes aware of a personal data breach, "it should notify the competent supervisory authority without undue delay, unless it can demonstrate, in accordance with the principle of accountability, that the breach is unlikely to result in a risk to the rights and freedoms of natural persons."

13

"A personal data breach may not pose a risk to the rights and freedoms of natural persons." It is noted that according to the wording of Article 33 of the GDPR and in contrast to the wording of Article 34 of the GDPR, the obligation to notify the Authority does not require the existence of a "high risk" for the data subject but simply a "risk" to their rights and freedoms. According to the aforementioned Guidelines of the EDPB 29, "Article 33(1) makes it clear that, in the case of a breach that 'is not likely to result in a risk to the rights and freedoms of natural persons', notification to the supervisory authority is not required. An example may be the case where personal data is already publicly available and its disclosure does not pose a likely risk to the individual" (wp 250 rev.01, p.21). From the above, it follows that the GDPR establishes a "presumption" of the obligation to notify the Authority of breach incidents, with the sole exception being the absence of risk to the rights and freedoms of the affected data subjects, for which the data controller bears the burden of proof if they choose not to make such notification.

6. The notification must contain at least the minimum information referred to in paragraph 3 of Article 33 of the GDPR, while according to paragraph 5 of the same article, "The data controller documents every personal data breach, consisting of the facts relating to the personal data breach, its effects, and the remedial actions taken. This documentation allows the supervisory authority to verify compliance with the current article." Regarding the time of knowledge of the incident by the Data Controller, the aforementioned Guidelines 18/2018 of the EDPB (wp 250) state the following: "As detailed above, the GDPR requires, in the event of a breach, that the data controller notify the breach without undue delay and, where feasible, within 72 hours of becoming aware of it. This raises the question of when a data controller can be considered to have 'knowledge' of a breach. The EDPB considers that a data controller should be deemed to have 'knowledge' when that data controller has a reasonable degree of certainty that a security incident has occurred that has resulted in personal data being compromised. However, as mentioned earlier, the GDPR requires the data controller to implement all appropriate technical and organizational measures for the immediate detection of any breach and the prompt notification of the supervisory authority and data subjects. It also states that it should be established that the notification was made without undue delay, taking into account in particular the nature and severity of the personal data breach, as well as the consequences and adverse effects for the data

subject. In this way, the data controller is obliged to ensure that they acquire 'knowledge' of any breaches in a timely manner so that they can take appropriate actions. The exact point in time when a data controller can be considered to have 'knowledge' of a specific breach will depend on the circumstances of that particular breach. In some cases, it will be relatively clear from the outset that a breach has occurred, while in others, it may take some time to ascertain whether personal data has been compromised. However, emphasis should be placed on timely action to address the situation."

15

"investigation of an incident, in order to determine whether personal data has been breached and, in such case, to take corrective measures and notify, if required." According to the above, Article 33 of the GDPR not only imposes the obligation to notify the supervisory authority of breach incidents but also the obligation to actively investigate any potential incident, provided that the data controller becomes aware of relevant indications. Otherwise, the data controller could easily circumvent its obligation to notify the supervisory authority of breach incidents by simply ignoring the indications of a potential incident and avoiding to ascertain and to "become aware" of it according to the above provision. Moreover, from paragraph 3 of Article 33 of the GDPR (content of the notification), it follows that the data controller has the obligation to promptly investigate the information mentioned therein, so as to be able to include it in the notification to the Authority (nature of the breach, categories and number of affected subjects, number of affected records, potential consequences of the breach, measures taken or proposed to address the breach, measures to mitigate potential adverse consequences), as well as to assess the risk to the rights and freedoms of the data subject,² in order to decide whether notification is required to them under Article 34 of the GDPR, while paragraph 5 of Article 33 of the GDPR explicitly states the obligation to maintain documentation for all the above processes. Moreover, based on the principle of accountability (Article 5, paragraph 2 of the GDPR), the data subject who has notified the data controller of a potential data breach is not required to take further active action for the latter to ascertain the existence or non-existence of a breach incident. This obligation rests with the data controller, who bears the responsibility to demonstrate its compliance.

7. Furthermore, the breach must also be communicated to the data subject, as applicable and in accordance with the provisions of Article 34, paragraphs 1 and 2 of the GDPR: "1. When a personal data breach is likely to result in a high risk to the rights and freedoms of natural persons, the data controller shall notify the personal data breach to the data subject without undue delay. 2. The notification to the data subject referred to in paragraph 1 of this Article shall describe in clear and plain language the nature of the personal data breach and shall contain at least the information and measures referred to in Article 33, paragraph 3, points (b), (c), and (d)."

8. In the present case, given the above-mentioned factual circumstances arising from the file's evidence and following the hearing process, it is initially established that the provision of personal data by the reported Bank regarding the use of the complainant's credit card to his wife was done unlawfully, in violation of the principle of legality, objectivity, and transparency of processing (Article 5, paragraph 1(a) of the GDPR) and in violation of the principle of confidentiality of data (Article 5, paragraph 1(f) of the GDPR). This unauthorized processing (disclosure by transmission) constitutes a personal data breach incident, according to the definition in Article 4, number 12 of the GDPR, which is attributed to an employee's error at the Bank. Specifically, as revealed by the Bank's relevant investigation and the conduct of a disciplinary review, on ..., during the visit of the complainant's wife to the Alpha Bank branch Ω X, with the purpose of being informed about the performance of joint investment products held with the complainant, the wife requested to be informed about the balance and transactions that had been conducted with the credit card that the complainant held exclusively in his name, assuring the employee that she had a relevant verbal authorization and...

17

Authorization from the complainant, as the data subject. The employee, misled regarding the existence of authorization, printed and provided the complainant's current personal credit card transactions to the complainant's wife, in violation of the relevant internal procedures and security measures of the Bank, which require written authorization (see memorandum of the respondent: "It is evident that this

particular employee wrongly accepted the verbal authorization of the wife as sufficient, despite the internal instructions and procedures of the Bank"). Subsequently, although the respondent Bank was informed of this incident on ... by the complainant, who even named one of the Bank's branches in the area of X as a possible source of the leak ("I suspect X"), and although it is evident that there was the possibility of checking the accesses that had occurred during the relevant period to the complainant's account information by its employees through its systems, the Bank did not take immediate active action to investigate the incident in order to obtain the necessary degree of certainty and to comply with its obligations under Article 33 of the GDPR, considering that the information it had at its disposal was not sufficient. Furthermore, although the complainant sent a related photograph of the account transaction copy that his wife had shown him to the Bank on ..., the Bank's Service "inadvertently," as it claims, did not forward this information to the Internal Audit Department, resulting in it still being unable, in its opinion, to initiate the investigation. In fact, this information does not appear to have been forwarded to the Internal Audit Department even on ..., when the latter, in a message to the Bank's Service, requested clarifications and further information regarding the case (see relevant document G/EIS/125/09-01-2023 from the respondent's opinions). Ultimately, the photograph of the printout of the complainant's credit card transactions was sent to the Internal Audit Department with significant delay on ..., that is, 1.5 months after the Bank received the relevant report from the complainant to the Consumer Ombudsman (...), which ultimately led to all information being sent to the Internal Audit Department, which finally issued the report on ...

18

confirming the leak and recording it as a violation incident. Subsequently, the Incident Assessment Committee met on ... (see the G/EIS/125/09-01-2023 response of the Bank), that is, 20 days after the above report. During the meeting, according to the same response, it was assessed that "based on the number and type of data concerning .. transactions via credit card that occurred over a period of approximately ... months (... to ...) and the fact that the unauthorized recipients of the above data are limited to one individual and indeed a relative of the complainant (spouse), there does not appear to be a risk to the freedoms and rights of the subject." Consequently, the Bank did not proceed with notifying the incident to the Authority in accordance with Article 33 of the GDPR, incorrectly characterizing the risk from this as "zero" (see Extract from the Incident Register, as referenced in the memorandum of the Bank), despite the fact that in the Risk Analysis and Assessment Form of the incident (referenced in the memorandum of the Bank) potential impacts for the subject have been recorded as "causing anxiety, stress, annoyance, and lack of trust regarding the leak of his credit card transactions to his wife." As indicated in the same Form, the severity of the impacts for the subject has been assessed as "negligible," while the likelihood of harm occurring to the subject is also characterized as "negligible," with the following justification: "The quantity and categories of data (transactions of a card for a maximum period of ... months) and the recipient of the data, the data leaked to a person within the closest family circle of the individual B, are estimated to significantly reduce the likelihood of high risks to the freedoms and rights of individual B. Following the above, the likelihood of a risk occurring to the rights and freedoms of the subject or harm being caused is deemed negligible." However, this assessment by the Bank is evidently erroneous, given that it is certain that the incident had consequences on the rights and freedoms of the subject.

3 It is noted that in the Risk Analysis Form of the violation incident, the date of confirmation of the incident is stated as ..., while the date of detection is ..., without this discrepancy being explained by the Bank.

19

of the complainant, as was already known to the Bank, disrupted his personal and family life. It also appears that the Bank underestimates the potential consequences of the violation, arguing in its memorandum that from the recording of daily transactions, such as payments to ... or ..., the type of service provided does not emerge, a claim that is evidently unfounded. Furthermore, in the same Risk Analysis and Assessment Form (Annex 2 of the memorandum), it is noted that "Due to the nature of the incident and given that the consequences of the incident can no longer be prevented, there is no

possibility for corrective actions on the part of the Bank,” an assessment that is also incorrect, as the Bank could, in any case, take measures to mitigate the consequences of the incident: For example, it could contact the complainant's wife and recipient of the complainant's data, inform her that the transmission of his transactional information to her had occurred unlawfully, in violation of the bank's procedures and banking confidentiality, and request her to return the relevant prints to the Bank and destroy any copies thereof, as well as not to disclose the relevant information to third parties. Thus, although the Bank acknowledges that in this case there was unlawful processing and improper transmission of the complainant's data and recorded the incident in the Data Breach Incident Register, it ultimately did not notify the Authority pursuant to Article 33 of the GDPR, did not take measures to mitigate the consequences of the incident, and did not take additional measures to prevent similar incidents in the future, beyond imposing a disciplinary penalty of a one-month suspension on the responsible employee, which, according to the Bank, is intended to act as a deterrent for the remaining staff. It is also noted that the Bank did not express any interest or even a formal apology for the moral damage suffered by the complainant due to the incident.

9. From the above-mentioned factual circumstances, a series of erroneous actions and omissions in the management of the incident of breach in question by the complained Bank emerge. Specifically, the Bank, as the data controller, despite having indications of a possible breach incident, initially did not investigate it, shifting the responsibility for identifying the source of the leak to the data subject, subsequently delayed significantly in handling it as a breach incident due to a lack of coordination among its competent Units, then underestimated its consequences for the data subject, and incorrectly assessed that it was not obliged to notify the Authority pursuant to Article 33 of the GDPR. The identified deficiencies and delays in the internal handling of the case do not appear to be due to inadequate Policies and Procedures of the Bank in accordance with Article 24(2) of the GDPR, as the actions that its bodies and services are obliged to follow without delay in the event of a potential breach incident are provided for in the documents that the Bank invoked and submitted (see Annexes 4-6 of the Bank's response letter No. Γ/ΕΙΣ/125/09-01-2023), but rather to the non-compliance with these procedures in the present case. Following the above, the Bank is found liable for the fact that it delayed for many months to investigate the incident in order to obtain a reasonable degree of certainty and to handle it as a breach incident, as well as for the fact that after confirming the incident, it did not proceed to notify the Authority nor did it take measures to mitigate its consequences.

10. Therefore, the Authority finds the following violations on the part of the complained Bank, as the data controller:

a) unlawful processing of the complainant's personal data, due to the transmission of his credit card transactions to a third party, which occurred without a legal basis, in violation of the principles of lawfulness of processing and data confidentiality (Article 5(1)(a) and (f) of the GDPR) and constitutes a breach incident (Article 4(12) of the GDPR).

21

b) Incorrect handling of the incident and failure to notify the Authority in violation of Article 33 GDPR.

11. Based on the above, the Authority deems it appropriate to exercise its corrective powers under Article 58(2) of the GDPR concerning the identified violations and that, based on the circumstances established, an effective, proportionate, and deterrent administrative fine should be imposed pursuant to Article 58(2)(h) of the GDPR, both to restore compliance and to punish the unlawful behavior. Furthermore, the Authority took into account the criteria for imposing fines set out in Article 83(2) of the GDPR, paragraph 5(a) of the same article applicable to the present case, the Guidelines for the application and determination of administrative fines for the purposes of Regulation 2016/679 issued on 03-10-2017 by the Article 29 Working Party (WP 253), and the Guidelines 04/2022 of the European Data Protection Board for calculating administrative fines under the General Regulation, as well as the factual data of the case under examination and particularly the criteria listed below, per violation.

A. Regarding the first identified violation (see paragraph 10(a)), the following specific circumstances are particularly taken into account:

a) that the violation of the legality of processing falls under the provision of paragraph 5 of Article 83

GDPR,

b) that the incident appears to be isolated, as no sanction has been imposed by the Authority on the Bank for a similar violation in the past,

c) that the violation directly affected one data subject, ...,

d) that the violation was due to human error by an employee attributed to negligence, while the Bank has established appropriate procedures that require written authorization as a condition for providing information to a third party,

e) that the Bank did not take measures to mitigate the immediate effects of the incident for the data subject, such as contacting the data recipient and requesting them to return to the Bank or destroy the data that was unlawfully provided to them,

f) that, however, the Bank ultimately conducted a disciplinary review of the employee who violated these procedures and imposed a disciplinary penalty.

B. Regarding the second identified violation (see paragraph 10(b)), the following criteria are particularly taken into account:

a) that the violation of the obligations of the data controller under Article 33 GDPR falls under the provision of paragraph 4 of Article 83 GDPR,

b) the degree of responsibility of the complainant, who, although having taken appropriate organizational measures and established relevant policies for managing data breach incidents, was found not to have implemented them in practice in this case,

c) that a delay of several months was identified in a process that should be conducted within 72 hours, indicating a possible attempt at concealment by the Bank, and in any case indifference towards compliance with its obligations under the GDPR,

d) that in the context of the Authority's investigation of the complaint, the Bank shifted the burden of responsibility for investigating the incident onto the data subject, in a manner that contradicts the principle of accountability,

e) that the Bank further disregarded the consequences of the incident on the data subject, of which it was aware and underestimated the risk to the subject to the point of characterizing it as "zero,"

f) that based on the above, it appears that the overall incorrect and unlawful handling of the incident by the Bank constitutes a systemic problem that could potentially affect other customers.

23

FOR THESE REASONS

THE AUTHORITY

A. Imposes on ALPHA BANK S.A. as the data controller, based on Article 58(2)(h) of the GDPR, an administrative fine of ten thousand (10,000€) euros, for the identified violation of the principles of legality of processing and confidentiality of data under Article 5(1)(a) and (f) GDPR.

B. Imposes on ALPHA BANK S.A., as the data controller, based on Article 58(2)(h) of the GDPR, an administrative fine of fifty thousand (50,000€) euros, for the identified violation of the obligation to handle and notify a data breach incident under Article 33 GDPR.

The President

The Secretary

Georgios Batzalexis

Irini Papageorgopoulou